Note de cadrage : investigation CTI de l'incident INC-2026-0302 (Helios Energy)

Statut : version finale du 2026-10-07, non relue par un tiers. Rédigée le 2026-10-06, mise à jour à la clôture. Elle était prévue pour la fin de J1 : **produite après coup, elle n'a pas été remise à temps.** Équipe, rôles et temps passé : **non communiqués** (aucun nom n'est inventé).

1. Contexte et mission

Helios Energy, fournisseur d'énergie fictif de 3 000 salariés présenté comme opérateur d'importance vitale (énoncé du sujet), a subi une intrusion observée entre le 2 et le 7 mars 2026. Le dossier annonce 40 IoC, 12 alertes SIEM, 3 binaires et un mémo. La victime est Helios Energy ; la recherche porte sur **l'attaquant**. Mission : corréler et enrichir les indicateurs, structurer le renseignement dans MISP, produire un bundle STIX 2.1 d'au moins 25 objets liés, rattacher les techniques à MITRE ATT&CK, appliquer le Diamond Model, argumenter une attribution, évaluer la fiabilité (Admiralty) et l'impact, restituer au niveau stratégique et tactique.

2. Ce qui a été reçu, tel qu'il est

Annoncé	Reçu	Écart
40 IoC	40 (CSV et JSON identiques, 0 doublon)	plages de documentation (RFC 5737) et domaines `.test`
12 alertes	12, toutes dans le journal brut	alerte 5 hors séquence
3 binaires	**3 fiches, 0 échantillon**	pas d'analyse statique ni de recalcul d'empreintes
1 mémo	1, daté du 2 mars mais décrivant des faits des 5 à 7 mars	date non fiable
n/a	1 journal brut (12 lignes utiles, 360 de bruit)	une seule journée de bruit

21 incohérences sont consignées et jamais corrigées dans les originaux.

3. Périmètre et règles de conduite

Dans le périmètre : analyse des artefacts, structuration dans MISP et OpenCTI de l'infrastructure existante (organisation et marquages dédiés), STIX, ATT&CK, attribution, règles de détection testées, rapports, notes ANSSI et TLP, soutenance. Hors périmètre sans accord explicite : publication ou partage externe, envoi d'IoC à un tiers, blocage, réponse active, analyse dynamique, suppression. Preuve avant conclusion : OBSERVÉ / CORROBORÉ / HYPOTHÈSE / INCONNU / NON TESTÉ. La « piste d'attribution » du LISEZ-MOI est une **indication, pas une preuve**.

4. Livrables et critères

36 exigences officielles (lecture du brief ; le dépôt Git est obligatoire depuis le sujet initial), 3 **demandes supplémentaires** OpenCTI (consultation, enquête, RFI) et 5 **éléments optionnels** (volet Wazuh, consultation indirecte du dark web par des sources en clair et correspondance MISP/OpenCTI traités ; Cortex et CrowdSec non applicables, non utilisés). Une exigence est « satisfaite et contrôlée » seulement si le livrable existe, son contenu est présent, la preuve est archivée, le contrôle est exécuté et les limites sont écrites ; sinon elle est « partielle » ou « non satisfaite », avec sa cause. Aucune n'a été relue par le commanditaire.

5. Méthode et planning

Cinq phases pédagogiques de 7 h (35 h prévisionnelles) : J1 cadrage et triage, J2 corrélation et enrichissement, J3 chaîne d'attaque et attribution, J4 rapports et règles Sigma, J5 conformité, graphe et soutenance. **Réalité : toutes les opérations ont eu lieu le 2026-10-06** ; le temps passé est inconnu et n'est pas renseigné. Méthode : scripts relançables, sorties archivées, preuves relues dans les originaux, aucun fichier factice.

6. Infrastructure

L'infrastructure existante est utilisée via Pharos, Ansible et les accès de la session : MISP (organisation dédiée, distribution 0), OpenCTI (6.9.21, marquage TLP:RED, aucun domaine créé), Wazuh (rejeu limité et complet, niveaux 4 à 7). Aucune stack locale n'a été déployée. Détail : `00-Pilotage/Inventaire-infrastructure.md`.

7. Risques principaux

Contamination de la production par des données fictives (enrichissement automatique tiers, flux Jira, synchronisation MISP) ; preuves absentes (échantillons, journal Security effacé) ; chronologie incertaine ; biais de confirmation sur l'attribution ; automatisations de Wazuh (seuil TheHive à 10). Parades : voir `99-Historique/Plan-modelisation-OpenCTI.md` et `07-Detection-Tests/Plan-tests.md`.

8. Décisions et limites finales

Équipe et temps non communiqués ; définition des « 25 objets liés » non fournie (non démontré sous la définition conservatrice) ; liste des exigences non confirmée ; objets de test maintenus dans les plateformes, retraits préparés et non demandés ; interfaces contrôlées. Registre : `00-Pilotage/Decisions-et-limites-finales.md`.